

Toron · Fonctionnalités

Sep 28, 2026 · @xoudark

Présentation

Toron est une plateforme de conformité pour les PME et ETI françaises. Elle couvre ISO 27001, NIS 2 (via le ReCyF de l'ANSSI) et le RGPD sur un socle unique, puis ISO 9001. Elle est hébergée dans l'Union européenne, chez Scaleway.

Sa promesse tient en une phrase : prouvez une fois, couvrez tout. Un contrôle interne est rattaché à toutes les exigences qu'il satisfait, dans tous les référentiels. Une preuve déposée une fois sert donc à ISO 27001, à NIS 2 et au questionnaire d'un client.

Toron s'adresse au RSSI ou au responsable qualité qui pilote la conformité, à la direction qui arbitre les risques, aux pilotes de mesures qui mettent à jour leurs actions et à l'auditeur qui consulte les preuves en lecture seule.

Ce que Toron ne fait pas, volontairement : scanner de vulnérabilités, plateforme de formation, simulation de phishing, AIPD complète, CMDB, signature électronique qualifiée eIDAS. Le poinçon des livrables est un sceau d'intégrité, pas une signature qualifiée, et le produit le dit clairement.

Modules fonctionnels

Toron compte 13 modules de socle, un pack GRC et sécurité de 4 modules et un pack qualité. Le moteur de référentiels et son cross-mapping sont le cœur : tous les autres modules s'y rattachent.

Module	Ce qu'il permet	Règle métier clé	Phase
Organisation, périmètres, rôles	Multi-entités et multi-sites, périmètres SMSI ou qualité, invitations, rôles avec matrice de droits par module	Le tenant est explicite dans l'URL et vérifié côté serveur ; un Lecteur reçoit un 403 sur toute écriture	M0
Référentiels et cross-mapping	Frameworks chargés comme données, arbre d'exigences, contrôles internes liés aux exigences en n-n, référentiels internes ou groupe	Supprimer un contrôle mappé liste d'abord les exigences qui se retrouvent découvertes	MVP

Module	Ce qu'il permet	Règle métier clé	Phase
Évaluations, gap analysis, SoA	Campagnes par référentiel, statut et justification par exigence, score de couverture, Déclaration d'applicabilité générée	Un « non applicable » sans justification est refusé ; les N/A ne comptent jamais dans le score	MVP
Risques	Registre brut, net et résiduel, matrice 4 × 4 configurable, traitements, acceptation formelle signée	Un risque « accepté » sans signature reste « acceptation en attente » et remonte en revue de direction	MVP
EBIOS RM guidé	Les 5 ateliers pas à pas, scénarios opérationnels en kill chain ATT&CK, livrable au format ANSSI	Les échelles de gravité et vraisemblance sont versionnées : en changer n'altère pas l'historique	V1
Plan d'action unifié	Une seule file d'actions nourrie par les risques, écarts, constats d'audit, NC et incidents ; table et kanban, relances	Le retard est calculé, jamais saisi ; une action née d'un écart garde le lien vers ses exigences	MVP
Gestion documentaire	Versions, date de revue et alertes ; en V1, workflow brouillon, relecture, approuvé, publié et accusés de lecture	Un document publié est immuable : toute modification crée une nouvelle version	MVP light, V1
Coffre de preuves	Dépôt avec empreinte SHA-256 à l'ingestion, lien aux contrôles, fraîcheur, collectes récurrentes, journal des accès	Une preuve expirée signale les exigences qu'elle couvre sans changer leur statut : l'humain décide	MVP
Audits internes	Programme pluriannuel, checklist tirée du référentiel, constats typés, rapport scellé, package pour le certificateur	La séparation des tâches est vérifiée quand on affecte un auditeur	V1

Module	Ce qu'il permet	Règle métier clé	Phase
Revue de direction	Ordre du jour 9.3 généré, commun à 27001 et 9001, décisions converties en actions, PV scellé	Les entrées sont figées à la date de la revue	V1
Tiers et fournisseurs	Registre avec tiering, clauses, campagnes de questionnaires avec scoring, attestations ; portail fournisseur en V2	Chaque attestation a une date de validité suivie	V1
Indicateurs et tableaux de bord	Tableau de bord par rôle : conformité, couverture par référentiel, actions en retard, fraîcheur des preuves	Chaque chiffre mène à sa donnée source, aucun KPI orphelin	MVP
Notifications	E-mails d'invitation, relances, expirations et échéances NIS 2 ; centre in-app en V1	Préférences réglables par utilisateur	MVP, V1
Import Excel et export	Assistant en 4 étapes pour risques, actions, actifs et fournisseurs ; export complet du tenant en JSON	Jamais d'échec silencieux : chaque ligne rejetée porte sa cause et une correction proposée	MVP
Incidents NIS 2	Qualification « incident important », échéancier 24 h, 72 h, J+30, déclaration ANSSI pré-remplie, volet CNIL	Les délais partent de la qualification ; la chronologie est immuable ; pas de clôture sans retour d'expérience	V1
Actifs et cartographie	Inventaire matériel, logiciel, données et flux, cotation DICP, lien actif et risque	Pas de CMDB maison : GLPI ou Intune par intégration en V3	MVP minimal, V1
Registre des obligations	Obligations par entité (NIS 2, RGPD, sectoriel), suivi MonEspaceNIS2, registre des traitements article 30	L'AIPD complète reste hors périmètre	V1

Module	Ce qu'il permet	Règle métier clé	Phase
Continuité d'activité	BIA avec RTO et RPO par processus, PCA et PRA versionnés, suivi des exercices	Les enseignements d'un exercice deviennent des actions	V2
Pack qualité (ISO 9001)	Processus, non-conformités et CAPA, satisfaction client	L'efficacité d'une NC est revérifiée à J+90 par défaut, par le moteur	V2

Parcours type

Une PME passe de ses fichiers Excel à une Déclaration d'applicabilité scellée en six étapes. C'est le parcours de démonstration du MVP, joué en 15 minutes sur le tenant fictif Meridiane Logistics.

1. Importer l'existant. Le registre des risques, les actions et les fournisseurs arrivent depuis Excel. L'assistant détecte les colonnes, puis montre chaque ligne rejetée avec sa cause.
2. Évaluer un référentiel. On lance une campagne ReCyF : chaque exigence reçoit un statut et une justification. Les exigences déjà couvertes par un contrôle mutualisé héritent de son statut, avec la trace de l'origine.
3. Faire ressortir les écarts. Le score de couverture et la liste des exigences non satisfaites apparaissent sur le tableau de bord.
4. Convertir les écarts en actions. Un clic crée l'action, déjà liée à l'exigence. Le pilote reçoit une relance à J-7.
5. Déposer les preuves. Chaque fichier est empreint en SHA-256 et rattaché au contrôle. S'il est lié à un contrôle mutualisé, il apparaît à la fois sur ISO 27001 et sur ReCyF.
6. Exporter la SoA scellée. Le PDF porte le poinçon, l'empreinte du fichier et une adresse de vérification que l'auditeur peut consulter.

Sécurité et confiance

Un outil de conformité doit passer lui-même le questionnaire fournisseur de ses clients. Ces fonctions sont visibles par l'utilisateur, pas seulement dans le code.

- Poinçon des livrables. Chaque export (SoA, registre des risques, rapport d'audit, PV de revue, déclaration d'incident) est scellé avec l'empreinte SHA-256 du fichier. Une page publique de vérification confirme qu'il n'a pas été modifié.

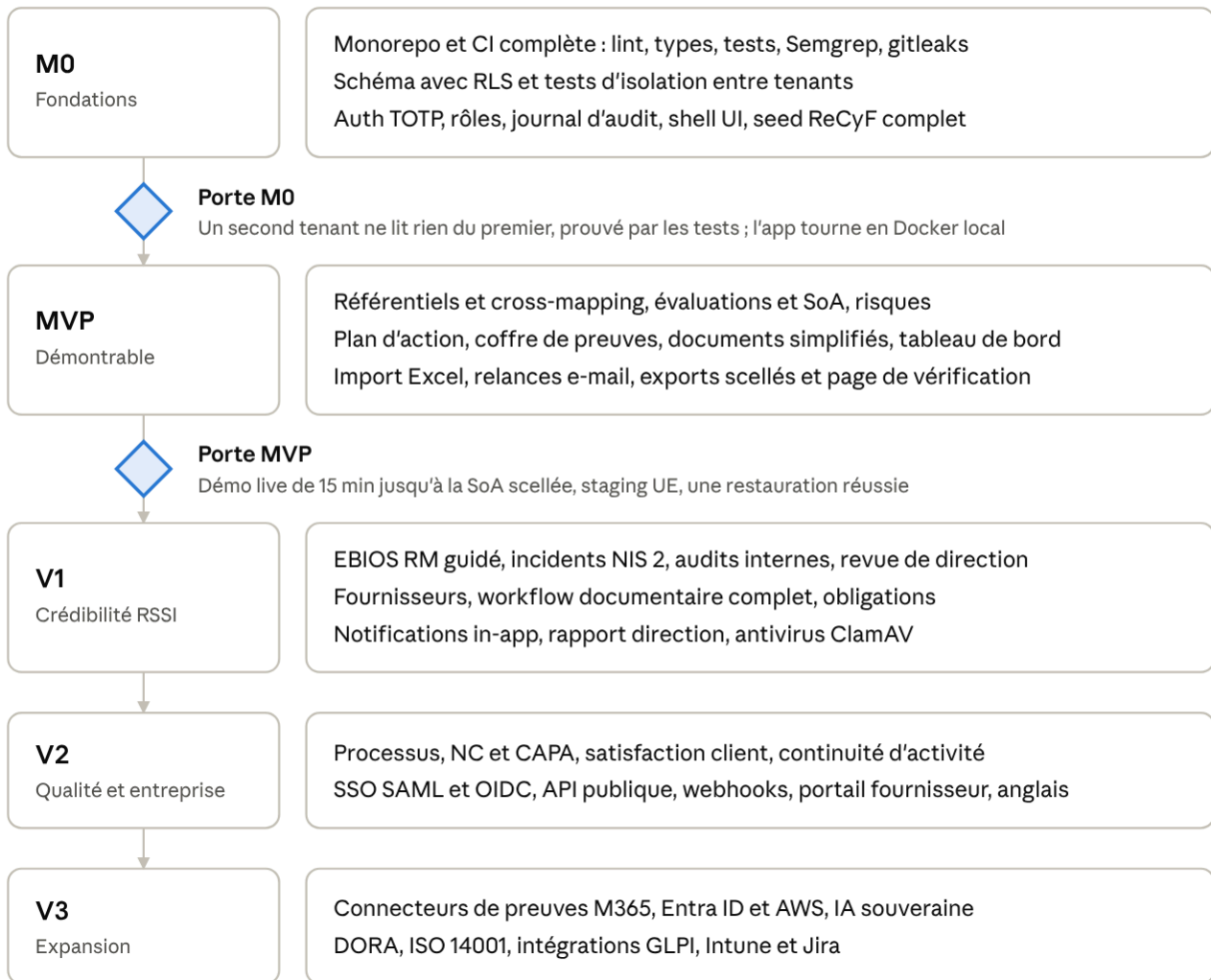
- Isolation entre clients. Chaque table métier porte un identifiant de tenant filtré par la Row Level Security de PostgreSQL. Une suite de tests tente des lectures et des écritures croisées avec des identifiants forgés, et bloque toute fusion si elle échoue.
- Journal d'audit immuable. Créations, modifications, suppressions, connexions, exports et changements de rôle y sont inscrits. Il est consultable et exportable, sans aucune fonction d'effacement, avec une rétention d'au moins un an.
- Authentification. Better Auth avec TOTP, obligatoire pour les rôles Administrateur et RSSI. SSO SAML ou OIDC en V2.
- Données. TLS partout, chiffrement au repos, sauvegardes quotidiennes avec restauration à un instant donné, test de restauration trimestriel documenté.
- Réversibilité. L'export complet du tenant en JSON avec les fichiers évite l'enfermement chez l'éditeur.
- IA, en V3 seulement. Inférence hébergée dans l'UE, activation par tenant, aucun entraînement sur les données clients. L'IA propose, l'humain statue.

Feuille de route

Toron avance en cinq phases, et aucune ne démarre avant que la définition de terminé de la précédente soit validée. M0 ne livre aucune fonctionnalité visible : elle prouve l'isolation entre clients avant tout le reste.

Chaque phase commence quand la précédente est au vert

Les demandes hors phase vont dans le backlog, pas dans le code



feuille de route · 5 phases, 2 portes

Seules les portes M0 et MVP ont des critères écrits ; celles de V1 et V2 restent à définir.